Nmap Scripting Engine

The NSE is another feature of NMAP. It provides us with the possibility to create scripts for interaction with certain services. NSE uses Lua Scripting Engine.

There are a total of 14 categories into which these scripts can be divided:

Category	Description
`auth`	Determination of authentication credentials.
`broadcast`	Scripts, which are used for host discovery by broadcasting and the discovered hosts, can be automatically added to the remaining scans.
`brute`	Executes scripts that try to log in to the respective service by brute-forcing with credentials.
`default`	Default scripts executed by using the `-sC` option.
`discovery`	Evaluation of accessible services.
`dos`	These scripts are used to check services for denial of service vulnerabilities and are used less as it harms the services.
`exploit`	This category of scripts tries to exploit known vulnerabilities for the scanned port.
`external`	Scripts that use external services for further processing.
`fuzzer`	This uses scripts to identify vulnerabilities and unexpected packet handling by sending different fields, which can take much time.
`intrusive`	Intrusive scripts that could negatively affect the target system.
`malware`	Checks if some malware infects the target system.
`safe`	Defensive scripts that do not perform intrusive and destructive access.
`version`	Extension for service detection.
`vuln`	Identification of specific vulnerabilities.

Default Scripts

pecna@htb[/htb]$ sudo nmap <target> -sC

Specific Scripts Category

pecna@htb[/htb]$ sudo nmap <target> --script <category>

Defined Scripts

pecna@htb[/htb]$ sudo nmap <target> --script <script-name>,<script-name>,...

Nmap - Specifying Scripts

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p 25 --script banne
r,smtp-commands

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-16 23:21
CEST
Nmap scan report for 10.129.2.28
Host is up (0.050s latency).

PORT   STATE SERVICE
25/tcp open  smtp
|_banner: 220 inlane ESMTP Postfix (Ubuntu)
|_smtp-commands: inlane, PIPELINING, SIZE 10240000, VRFY, E
TRN, STARTTLS,
ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8,
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-p 25`	Scans only the specified port.
`--script banner,smtp-commands`	Uses specified NSE scripts.

We see that we can recognize the **Ubuntu** distribution of Linux by using the' banner' script. The `smtp-commands` script shows us which commands we can use by interacting with the target SMTP server. In this example, such information may help us to find out existing users on the target. `Nmap` also gives us the ability to scan our target with the aggressive option (`-A`). This scans the target with multiple options as service detection (`-sV`), OS detection (`-O`), traceroute (`--traceroute`), and with the default NSE scripts (`-sC`).

Nmap - Aggressive Scan

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p 80 -A
Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-17 01:38
CEST
Nmap scan report for 10.129.2.28
Host is up (0.012s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-generator: WordPress 5.3.4
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: blog.inlanefreight.com
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)
Warning: OSScan results may be unreliable because we could
not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 2.6.32 (96%), Linux 3.2 - 4.9
(96%), Linux 2.6.32 - 3.10 (96%), Linux 3.4 - 3.10 (95%), L
inux 3.1 (95%), Linux 3.2 (95%),
AXIS 210A or 211 Network Camera (Linux 2.6.17) (94%), Synol
ogy DiskStation Manager 5.2-5644 (94%), Netgear RAIDiator
4.2.28 (94%),
Linux 2.6.32 - 2.6.35 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   11.91 ms 10.129.2.28

OS and Service detection performed. Please report any incor
rect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.36 second
s
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-p 80`	Scans only the specified port.

Scanning Options	Description
`-A`	Performs service detection, OS detection, traceroute and uses defaults scripts to scan the target.

With the help of the used scan option (`-A`), we found out what kind of web server (`Apache 2.4.29`) is running on the system, which web application (`WordPress 5.3.4`) is used, and the title (`blog.inlanefreight.com`) of the web page.
Also, `Nmap` shows that it is likely to be `Linux` (`96%`) operating system.

Vulnerability Assessment

HTTP port 80 and see what information and vulnerabilities we can find using the vuln category from NSE

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p 80 -sV --script v
uln

Nmap scan report for 10.129.2.28
Host is up (0.036s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
| http-enum:
|   /wp-login.php: Possible admin folder
|   /readme.html: Wordpress version: 2
|   /: WordPress version: 5.3.4
|   /wp-includes/images/rss.png: Wordpress version 2.2 foun
d.
|   /wp-includes/js/jquery/suggest.js: Wordpress version 2.
5 found.
|   /wp-includes/images/blank.gif: Wordpress version 2.6 fo
und.
|   /wp-includes/js/comment-reply.js: Wordpress version 2.7
found.
|   /wp-login.php: Wordpress login page.
|   /wp-admin/upgrade.php: Wordpress login page.
|_  /readme.html: Interesting, a readme.
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-stored-xss: Couldn't find any stored XSS vulnerabili
```

```
ties.
| http-wordpress-users:
| Username found: admin
|_Search stopped at ID #25. Increase the upper limit if nec
essary with 'http-wordpress-users.limit'
| vulners:
|   cpe:/a:apache:http_server:2.4.29:
|       CVE-2019-0211   7.2 https://vulners.com/cve/CVE-201
9-0211
|       CVE-2018-1312   6.8 https://vulners.com/cve/CVE-201
8-1312
|       CVE-2017-15715  6.8 https://vulners.com/cve/CVE-201
7-15715
<SNIP>
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-p 80`	Scans only the specified port.
`-sV`	Performs service version detection on specified ports.
`--script vuln`	Uses all related scripts from specified category.